Equifax Data Breach

When Security Failures Cost Billions

Suresh Paul

Algorithm Basics and BW

Equifax Data Breach

When Security Failures Cost Billions

143 million lives compromised by preventable failures

Learning Objectives

1. ⚠ How cascading security failures enable massive breaches
2. $ True costs of data breaches (financial, reputational, legal)
3. 🔨 Corporate governance and accountability in cybersecurity
4. 🛡 Defense-in-depth security architecture principles
5. 👥 Consumer rights and protections after data breaches

Key Question: Who's accountable when your data is breached through negligence?

Background: What is Equifax?

Company profile:

- One of 3 major credit bureaus
  - Equifax, Experian, TransUnion
- Maintains credit data on:
  - 800M+ consumers worldwide
  - 88M+ businesses
- $3.4B revenue (2016)
- 11,000 employees
- 24 countries

Data collected:

- Personal info:
  - SSN, birth date, address, phone
- $ Financial data:
  - Credit cards
  - Loans, mortgages
  - Payment history
- Credit scores
- Employment history

Critical fact: Consumers don't choose Equifax—it collects data automatically

Background: Why Credit Bureaus Matter

Their role:

- Enable lending decisions
  - Mortgages, car loans
  - Credit cards
  - Apartment rentals
- Provide credit scores
- Central data repositories
- No consumer choice
  - Banks report to them
  - You can't opt out

Background: Why Credit Bureaus Matter

Credit score formula:

$$\begin{aligned}\text{Probability of good standing} =& 0.35 \times H \\ &+ 0.30 \times O \\ &+ 0.15 \times L \\ &+ 0.10 \times N \\ &+ 0.10 \times M\end{aligned}$$

where H is a sub-score for payment history, O for amounts owed, L for length, N for new credit, and M for mix (each internally mapped to a 0-100 or similar scale).

$$\text{Score} = 300 + (\text{Probability of good standing} \times 500)$$

Background: Why Credit Bureaus Matter

The problem:

- ✗ Consumers are product, not customer
- ✗ Banks are customers
- ✗ No competitive pressure for security
- ✗ Massive target for hackers

Market structure:

- Oligopoly (only 3 major players)
- High barriers to entry
- Network effects
- Essentially unavoidable

Key insight: When you can't choose provider, security becomes even more critical

The Breach: Timeline of Disaster

Key dates:

- **March 7, 2017:**
  - Apache Struts vulnerability announced
  - CVE-2017-5638
  - Patch immediately available
- **March 8-10, 2017:**
  - Equifax's scanner missed vulnerability
  - No patch applied
- **Mid-May 2017:**
  - Breach begins
  - Hackers enter system

The Breach: Timeline of Disaster

Discovery & response:

- **July 29, 2017:**
  - Breach discovered (76 days!)
- **$ August 1-2, 2017:**
  - Executives sell stock
  - Before public announcement
- **September 7, 2017:**
  - Public disclosure
  - 143M people affected (later 147.9M)

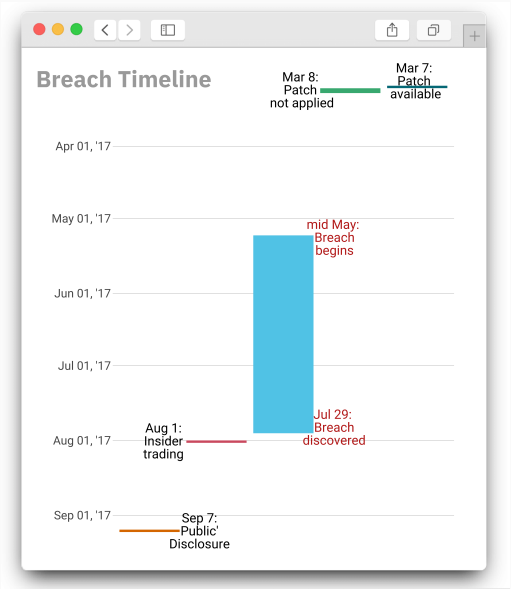
Shocking fact: 76 days of undetected access to 147.9M records

Breach Timeline Visualization (The 6-month disaster)

- March 7: Patch available
- March 8-10: Not applied
- Mid-May: Breach starts
- 76 days undetected
- July 29: Finally discovered
- $ Aug 1-2: Insider trading
- Sept 7: Public learns

Key question:

Why did it take 76 days to detect?



What Was Stolen: The Data

Personal information compromised

147.9 million Americans:

- Names
- Social Security numbers
- Birth dates
- Home addresses
- Driver's license numbers (10.9M)
- Credit card numbers (209,000)

Scale:

- Nearly half of US population
- Most comprehensive breach ever
- Perfect for identity theft

The Delayed Response: 76 Days (Why wasn't it detected sooner?)

What should have happened:

- ✅ Real-time monitoring
  - Detect unusual data access
  - Alert on large transfers
- ✅ Automated responses
  - Block suspicious traffic
  - Isolate compromised systems
- ✅ Security operations center
  - 24/7 monitoring
  - Incident response team

Industry standard: Most breaches detected in days, not months

Corporate Governance Failures

Leadership accountability:

- Rick Smith, CEO
  - Resigned September 2017
  - Kept $90M in stock/pension
- Susan Mauldin, CSO
  - Music major, not security expert
  - Retired immediately after breach
- David Webb, CIO
  - Retired immediately

Board oversight:

- No security expertise
- Insufficient oversight
- Reactive, not proactive

Corporate Governance Failures

Insider trading allegations:

- $ Three executives sold stock
  - Aug 1-2, 2017
  - After breach discovered
  - Before public announcement
  - $1.8M in stock sales
- SEC investigation
- Did they know?

Culture problems:

- Security not prioritized
- Cost-cutting over protection
- Technical debt accumulated
- No accountability culture

Question: Should executives face criminal charges for negligence?

Financial Impact: $1.4 Billion+ (The true cost of negligence)

Direct costs:

- Consumer settlement: $425M
  - Class action lawsuit
  - $125-$425 per person
- FTC fine: $100M
- CFPB fine: $100M
- State fines: $175M
  - 50 state attorneys general
- Legal fees: $242M
- Credit monitoring: $350M
  - 10 years for victims

Financial Impact: $1.4 Billion+ (The true cost of negligence)

Indirect costs:

- Stock price drop: 30%+
  - Market cap loss: $5B+
- Lost business
- Reputation damage
- Technology upgrades: $200M

Total estimated cost:

- **$** $1.4B+ direct
- **$** $5B+ total impact

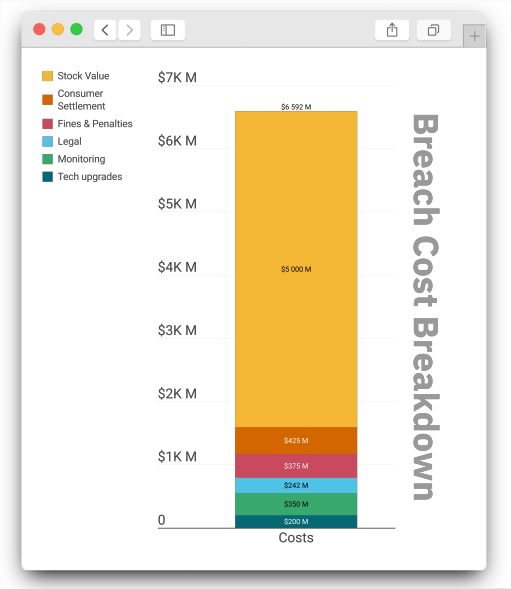
Per victim: $1.4B cost / 147.9M
= **$9.47 per person**
(but victims got $2.88 average!)

Is this the real cost of losing private information?

Cost Breakdown (Where the money went)

- Consumer settlement: $425M
- FTC: $100M
- CFPB: $100M
- States: $175M
- Legal: $242M
- Monitoring: $350M
- Tech upgrades: $200M
- **Total: $1.59B**

Plus: Stock value loss ($5B)



Victim Impact: The Human Cost (What happened to the 147.9 M victims)

Immediate impact:

- ⚠ SSN exposed forever
  - Can't change it
  - Permanent vulnerability
- 🪪 Identity theft risk
  - Credit card fraud
  - Tax fraud
  - Medical fraud
- 🕒 Time burden
  - Monitor credit reports
  - Freeze credit
  - Dispute fraudulent charges

Victim Impact: The Human Cost (What happened to the 147.9 M victims)

Long-term consequences:

- Lifetime vigilance required
- Anxiety and stress
- $ Financial losses
  - Even with monitoring
  - Fraud still possible

Inadequate compensation:

- Settlement options
  - $125 cash or credit monitoring
  - Average actual payout: $2.88
- Lifetime risk for $2.88?

The injustice:

- Victims didn't choose Equifax
- Can't sue effectively
- Got minimal compensation

Lesson 1: Patch Management is Non-Negotiable

The failure:

- Critical patch available March 7
- Not applied by Equifax
- Vulnerability scanner missed it
- Breach began in May
- 2+ months to exploit

What should happen:

- Critical patches within 24-48 hours
- Automated scanning
- Verification after patching
- Emergency procedures for critical CVEs

Lesson 1: Patch Management is Non-Negotiable

Broader implications:

- Technical debt kills
  - Old systems harder to patch
  - Accumulates risk
- Staffing matters
  - Need enough people
  - Need right expertise
- $ Cost of prevention $<$ breach
  - Patching: $10,000s
  - Breach: $1,000,000,000s

Industry standard: 24 hours for critical patches, 7 days for high severity

Lesson 2: Defense in Depth Required

Single layer of defense = guaranteed failure

Equifax's single point of failure:

- ✗ One vulnerability = total breach
- ✗ No network segmentation
- ✗ No encryption at rest
- ✗ No anomaly detection
- ✗ One failure cascaded to total compromise

Defense in depth approach:

- ✓ Multiple layers
- ✓ Each layer independent
- ✓ Breach contained at each layer

Lesson 2: Defense in Depth Required

Single layer of defense = guaranteed failure

Required layers:

1. Perimeter defense (firewall)
2. Network segmentation
3. Access control (IAM)
4. Encryption at rest
5. Encryption in transit
6. Monitoring & logging
7. Intrusion detection
8. Data classification

Principle:

If one layer fails, others contain breach

Key insight: Assume breach will happen—design to limit damage

Lesson 3: You Don't Own the Data You Collect

Equifax's attitude:

- "We collected it, we own it"
- Treated as corporate asset
- Minimal protection
- No accountability to consumers

Correct attitude:

- Stewardship, not ownership
- Fiduciary duty to protect
- Accountable to data subjects
- Legal obligations

Lesson 4: Security Monitoring Must Actually Work

Equifax's monitoring failure:

- SSL certificate expired
  - 19 months overdue
  - Monitoring couldn't inspect traffic
- 76 days undetected
  - Massive data exfiltration
  - No alerts triggered
- What was monitoring doing?

The problem:

- Monitoring tools deployed
- But not actually monitoring
- False sense of security

Ethics Discussion: Accountability (Who should be held accountable?)

The players:

- CEO Rick Smith
  - Set security budget
  - Resigned with $90M
- CSO Susan Mauldin
  - Responsible for security
  - Music major, not security expert
- Board of Directors
  - No security expertise
  - Insufficient oversight
- </> IT team
  - Didn't patch
  - Let SSL expire

Ethics Discussion: Consumer Rights (The victim's dilemma)

Policy questions:

1. ⚖ Should compensation be higher?
   - $1,000 per victim?
   - $10,000?
2. 🔨 Should consumers have right to opt out?
3. 👥 Should Equifax exist today?
   - Public utility?
   - Break up?
   - Nationalize?
4. 🔒 Should there be security minimums?

Question: If you can't choose your data collector, what rights should you have?

Key Takeaways

1. ⚠ **Patch management non-negotiable:** Critical patches within 24-48 hours, no exceptions

2. 🛡 **Defense in depth required:** Single layer of defense guarantees total compromise

3. 👥 **Stewardship, not ownership:** You don't own collected data—you're responsible for protecting it

4. 👁 **Monitoring must work:** Security theater $\neq$ actual security—test your defenses

Key Takeaways

5. **$ Cost of prevention $<<$ breach:** $1.4B breach vs $10K patching
6. **Accountability gap:** Current penalties don't change behavior—executives kept millions
7. **Victims powerless:** No choice, minimal compensation, lifetime risk

References

- US Government Accountability Office: "Equifax Data Breach" Report
  Official investigation findings and timeline
- Senate Committee Report: Equifax Breach Investigation
  Congressional testimony and analysis
- Breach Sense: "7 Critical Failures in Equifax Breach"
  `https://breachsense.io/7-critical-failures-in-equifax-breach/`
- Seven Pillars Institute: "Equifax Data Breach Case Study"
  Ethics and accountability analysis
- FTC Settlement Documentation
  Details of consumer compensation and fines